

./05-security/DOC-07-Security-Architecture.md

DOC-07: Security Architecture & Threat Model

Version: 1.0 | **Status:** APPROVED | **Date:** 2026-08-27 **Purpose:** Define security controls, threat models, and standards. **Owner:** Security Architect

Security Principles

- **Authentication:** JWT Access Tokens (short-lived) + Refresh Tokens (longer-lived, stored securely).
- **Passwords:** Argon2id hashing.
- **RBAC:** Backend enforces permissions strictly.
- **Tenant Isolation:** Backend determines tenant context from the authenticated user, NEVER trusting client-provided `organization_id`.

Security Controls

- **API Security:** Rate limiting via Redis, CORS policy, Input validation via DTOs.
- **Data Protection:** Soft deletion for critical records. PostgreSQL Row-Level Security (RLS) considered for future defense-in-depth.
- **Audit Logging:** Immutable audit logs for sensitive operations (CREATE, UPDATE, DELETE, APPROVE, REJECT).
- **Secrets Management:** Environment variables only. No hardcoded secrets in Git.

Critical Protections

- **Last Admin Rule:** System prevents deleting or demoting the last active Owner/Admin.
- **Confirmation UX:** Destructive actions require explicit confirmation (future: re-authentication or 2FA).